Guía de lectura

Unidad VI – Gestión de Identidades y Accesos (IAM)

Ciberseguridad Aplicada
Licenciatura en Ciberdefensa

2026

Presentación

Esta guía acompaña la lectura de la **Unidad VI: Gestión de Identidades y Accesos (IAM)**. El objetivo es orientar el estudio de los conceptos principales trabajados en la presentación y ayudar a relacionarlos con situaciones concretas de una organización.

La unidad aborda la gestión de identidades, usuarios, autenticación, autorización y accesos, incorporando además aspectos vinculados con terceros, cuentas privilegiadas, Active Directory, mínimo privilegio, RBAC, ABAC, ACL y Zero Trust.

1. Objetivos de lectura

Al finalizar la unidad se espera que el estudiante pueda:

- Comprender qué es la Gestión de Identidades y Accesos (IAM) y cuál es su finalidad.
- Diferenciar identidad, usuario, autenticación, autorización y acceso.
- Reconocer los principales factores y mecanismos de autenticación.
- Comprender el ciclo de vida de las cuentas y usuarios.
- Identificar responsabilidades y obligaciones asociadas a la gestión de usuarios.
- Reconocer riesgos relacionados con cuentas privilegiadas, terceros y cuentas inactivas.
- Comprender el rol de Active Directory dentro de una infraestructura organizacional.
- Aplicar el principio de mínimo privilegio.
- Diferenciar modelos de autorización como RBAC y ABAC.
- Comprender el funcionamiento conceptual de las ACL.
- Relacionar IAM con segmentación de redes y el enfoque Zero Trust.

2. Cómo abordar la lectura

Se recomienda realizar la lectura teniendo a disposición la presentación de la unidad. No es necesario memorizar definiciones de manera aislada. Es más importante comprender **qué problema resuelve cada mecanismo**, qué riesgos busca reducir y cómo se relaciona con los demás componentes de IAM.

Durante la lectura, intentá responder:

1. ¿Quién es la persona o entidad que intenta acceder?
2. ¿Cómo se demuestra que es quien dice ser?
3. ¿Qué recursos puede utilizar?
4. ¿Qué acciones está autorizada a realizar?
5. ¿Quién decide esos permisos?
6. ¿Qué ocurre cuando cambia de función?
7. ¿Qué ocurre cuando deja la organización?

3. Conceptos centrales

3.1. Identidad

La identidad representa el conjunto de atributos que permiten distinguir a una persona, sistema, servicio o entidad dentro de un entorno. En un sistema de información, la identidad permite asociar una actividad con una entidad determinada.

3.2. Usuario

El usuario constituye una representación operativa de una identidad dentro de un sistema. Una organización puede utilizar cuentas de usuario para permitir que una persona interactúe con aplicaciones, sistemas, redes y servicios.

3.3. Acceso

El acceso es la posibilidad efectiva de utilizar un recurso. No debe confundirse con la identidad: conocer quién es una persona no significa que esa persona deba tener acceso a todos los recursos.

3.4. Autenticación

La autenticación permite comprobar la identidad declarada por una entidad. La pregunta fundamental es:

¿Quién sos?

3.5. Autorización

La autorización determina qué acciones puede realizar una identidad autenticada. La pregunta fundamental es:

¿Qué estás autorizado a hacer?

Esta distinción es fundamental para comprender IAM:

$$Identidad \rightarrow Autenticación \rightarrow Autorización \rightarrow Acceso$$

4. Autenticación y factores

La autenticación puede utilizar diferentes factores. Entre los principales se encuentran:

- **Algo que sé:** contraseñas, PIN u otros secretos.
- **Algo que tengo:** tokens, dispositivos o claves físicas.
- **Algo que soy:** características biométricas.

La combinación de factores permite incrementar la seguridad frente a la utilización de un único mecanismo.

La lectura debe prestar especial atención a la diferencia entre **identificar**, **autenticar** y **autorizar**.

5. Gestión del ciclo de vida de los usuarios

La gestión de usuarios no termina con la creación de una cuenta. Una organización debe administrar el ciclo de vida completo.

5.1. Alta

Cuando una persona ingresa a una organización, debe existir un procedimiento que permita crear su identidad y asignarle los accesos necesarios para realizar sus funciones.

5.2. Modificación

Cuando una persona cambia de función, área o responsabilidades, sus permisos deben revisarse. Mantener permisos correspondientes a funciones anteriores puede generar privilegios innecesarios.

5.3. Baja

Cuando una persona deja de pertenecer a la organización, sus cuentas y accesos deben ser revocados de manera oportuna.

5.4. Revisión periódica

Las organizaciones deben revisar las cuentas y los permisos para detectar accesos innecesarios, cuentas inactivas, privilegios excesivos o situaciones que requieran corrección.

6. Tipos de cuentas

La gestión de identidades comprende diferentes tipos de cuentas.

6.1. Cuentas personales

Están asociadas a una persona determinada. Permiten mantener trazabilidad sobre las actividades realizadas.

6.2. Cuentas privilegiadas

Poseen capacidades superiores a las cuentas comunes, por ejemplo, administración de sistemas, configuración de servicios o gestión de usuarios.

Por su impacto potencial, requieren controles reforzados, trazabilidad y una asignación cuidadosamente justificada.

6.3. Cuentas de servicio

Son utilizadas por aplicaciones, procesos o servicios para realizar determinadas operaciones. Deben gestionarse teniendo en cuenta sus credenciales, permisos, dependencia técnica y ciclo de vida.

6.4. Cuentas genéricas o compartidas

Presentan dificultades para determinar qué persona realizó una acción. Por ello, su utilización debe estar restringida y, cuando sean necesarias, deben existir mecanismos compensatorios de control y trazabilidad.

7. Responsabilidades en la gestión de usuarios

IAM involucra responsabilidades distribuidas entre diferentes actores. La gestión debe contemplar quién solicita un acceso, quién lo aprueba, quién lo implementa y quién controla posteriormente que continúe siendo necesario.

El objetivo es evitar que una misma persona pueda crear, aprobar y mantener privilegios sin controles adecuados.

8. Terceros y proveedores

El acceso de terceros introduce riesgos adicionales. Proveedores, contratistas y organizaciones externas pueden necesitar acceso a sistemas o información para prestar servicios.

La gestión debe considerar:

- alcance del acceso;
- duración;
- responsabilidades;
- mecanismos de autenticación;
- registro y monitoreo;
- condiciones de finalización;
- requisitos de seguridad establecidos contractualmente.

8.1. Acuerdos de nivel de servicio

Los acuerdos de nivel de servicio (SLA) pueden establecer responsabilidades, niveles de servicio y condiciones relacionadas con la prestación. Desde la perspectiva de seguridad, los acuerdos con terceros deben contemplar los controles necesarios para proteger la información y los sistemas involucrados.

8.2. Evaluación y auditoría

La organización debe poder evaluar el cumplimiento de los requisitos establecidos y conservar evidencia suficiente para realizar controles y auditorías.

9. Datos personales y privacidad

La gestión de identidades implica el tratamiento de información asociada a personas. Por este motivo, las organizaciones deben considerar los principios y obligaciones establecidos por la normativa aplicable en materia de protección de datos personales.

El acceso a información personal debe estar limitado a quienes lo necesitan para cumplir funciones legítimas, aplicando controles adecuados y evitando exposiciones innecesarias.

10. Cuentas y finalización de la relación

Uno de los momentos críticos de IAM es la finalización de la relación laboral o contractual. La baja debe contemplar, según corresponda:

- deshabilitación de cuentas;
- revocación de permisos;
- revocación de credenciales;
- retiro de accesos remotos;
- recuperación de dispositivos o mecanismos de autenticación;
- revisión de cuentas de servicio o recursos asociados;
- conservación de registros cuando corresponda.

El objetivo es evitar que una identidad que ya no necesita acceder continúe disponiendo de mecanismos de entrada a los sistemas.

11. Active Directory

Active Directory constituye una infraestructura de directorio ampliamente utilizada en entornos Windows. Permite centralizar información sobre usuarios, equipos, grupos y otros objetos, y proporciona mecanismos que pueden utilizarse para implementar políticas y administrar accesos dentro de un dominio.

Para esta unidad interesa comprender su relación con IAM, particularmente:

- usuarios;
- grupos;
- equipos;
- políticas;
- autenticación;
- administración centralizada;
- permisos y privilegios.

Debe tenerse presente que Active Directory no equivale por sí solo a toda la disciplina IAM: constituye una pieza de infraestructura que soporta determinadas funciones de identidad y acceso.

12. Principio de mínimo privilegio

El principio de mínimo privilegio establece que una identidad debe disponer únicamente de los privilegios necesarios para realizar sus funciones.

El objetivo es reducir la superficie de ataque y limitar el impacto potencial de una cuenta comprometida.

Una pregunta útil para evaluar un permiso es:

¿Esta persona o servicio necesita realmente este acceso para realizar su tarea?

Si la respuesta es negativa, el permiso debería revisarse.

13. Autorización

Una vez autenticada una identidad, el sistema debe determinar qué puede hacer.

La autorización puede implementarse mediante diferentes modelos.

13.1. RBAC

El modelo **Role-Based Access Control (RBAC)** asigna permisos a roles y posteriormente asigna usuarios a dichos roles.

Por ejemplo:

$$Usuario \rightarrow Rol \rightarrow Permisos$$

Esto permite administrar permisos a partir de las funciones organizacionales.

13.2. ABAC

El modelo **Attribute-Based Access Control (ABAC)** utiliza atributos para tomar decisiones de autorización.

Estos atributos pueden estar asociados con:

- el usuario;
- el recurso;
- la acción;
- el contexto.

ABAC permite construir políticas más dinámicas y dependientes del contexto.

13.3. ACL

Una **Access Control List (ACL)** define reglas asociadas a un recurso, indicando qué identidades o grupos tienen determinados permisos.

Las ACL permiten expresar decisiones concretas de acceso, aunque su administración puede volverse compleja cuando aumenta la cantidad de usuarios, recursos y reglas.

14. Zero Trust

El enfoque Zero Trust parte de la idea de que no debe existir una confianza implícita basada únicamente en la ubicación de una identidad dentro de la red.

En lugar de asumir que una entidad es confiable por encontrarse "dentro" de la organización, se busca verificar explícitamente las solicitudes de acceso y aplicar controles de manera continua.

En relación con IAM, esto implica prestar especial atención a:

- identidad;
- autenticación;
- autorización;
- contexto;
- privilegios;
- monitoreo.

Una idea central es:

No confiar implícitamente; verificar antes de conceder acceso.

15. Segmentación

La segmentación consiste en separar recursos, sistemas o redes de acuerdo con criterios de seguridad y operación.

Su relación con IAM aparece cuando los permisos de una identidad se combinan con controles de red y arquitectura para limitar qué recursos puede alcanzar.

La segmentación correctamente diseñada puede contribuir a reducir el movimiento lateral de un atacante y limitar el alcance de un incidente.

16. Preguntas para comprobar la comprensión

1. ¿Cuál es la diferencia entre identidad, autenticación y autorización?
2. ¿Por qué una cuenta personal facilita la trazabilidad?
3. ¿Qué riesgos presentan las cuentas privilegiadas?
4. ¿Qué diferencia existe entre una cuenta personal y una cuenta de servicio?
5. ¿Por qué debe gestionarse el ciclo de vida completo de una cuenta?
6. ¿Qué controles deberían considerarse para el acceso de terceros?
7. ¿Qué problema busca reducir el principio de mínimo privilegio?
8. ¿Cuál es la diferencia conceptual entre RBAC y ABAC?
9. ¿Qué información puede representar una ACL?
10. ¿Qué relación existe entre IAM y Zero Trust?
11. ¿Por qué la segmentación puede contribuir a contener un incidente?
12. ¿Qué función cumple Active Directory dentro de una arquitectura de identidad?

17. Para relacionar los conceptos

Pensá en una organización donde una persona cambia de puesto.
Analizá el caso desde IAM:

1. ¿Qué sucede con su identidad?
2. ¿Qué permisos tenía antes?
3. ¿Qué permisos necesita ahora?
4. ¿Qué permisos deberían revocarse?
5. ¿Quién solicita el cambio?
6. ¿Quién lo aprueba?
7. ¿Quién implementa el cambio?
8. ¿Cómo se verifica posteriormente que los permisos sean correctos?

Este ejercicio permite integrar identidad, ciclo de vida, autorización, mínimo privilegio, responsabilidades y auditoría.